

Fascicule 7

```
safa@safa-virtual-machine:~/Desktop$ sudo apt upgrade
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Calculating upgrade... Done
The following packages were automatically installed and are no longer required:
  libflashrom1 libftdi1-2 libllvm13
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
  firefox libllvm15 linux-headers-6.8.0-106-generic
  linux-hwe-6.8-headers-6.8.0-106 linux-hwe-6.8-tools-6.8.0-106
  linux-image-6.8.0-106-generic linux-modules-6.8.0-106-generic
  linux-modules-extra-6.8.0-106-generic linux-tools-6.8.0-106-generic
  ubuntu-pro-client ubuntu-pro-client-l10n
The following packages will be upgraded:
  alsa-ucm-conf apache2 apache2-bin apache2-data apache2-utils apparmor
```

```
safa@safa-virtual-machine:~/Desktop$ sudo apt install docker.io
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following packages were automatically installed and are no longer required:
  libflashrom1 libftdi1-2 libllvm13 linux-headers-6.8.0-90-generic
  linux-hwe-6.8-headers-6.8.0-90 linux-hwe-6.8-tools-6.8.0-90
  linux-image-6.8.0-90-generic linux-modules-6.8.0-90-generic
  linux-modules-extra-6.8.0-90-generic linux-tools-6.8.0-90-generic
Use 'sudo apt autoremove' to remove them.
The following additional packages will be installed:
  bridge-utils containerd git git-man liberror-perl pigz runc ubuntu-fan
Suggested packages:
```

```
lib/systemd/system/docker.socket.
Setting up git (1:2.34.1-1ubuntu1.17) ...
Processing triggers for man-db (2.10.2-1) ...
safa@safa-virtual-machine:~/Desktop$ docker --version
Docker version 28.2.2, build 28.2.2-0ubuntu1~22.04.1
safa@safa-virtual-machine:~/Desktop$
```

```
safa@safa-virtual-machine:~/Desktop$ sudo systemctl start docker
safa@safa-virtual-machine:~/Desktop$ sudo systemctl enable docker
safa@safa-virtual-machine:~/Desktop$ docker pull webgoat/goatandwolf
Using default tag: latest
permission denied while trying to connect to the Docker daemon socket at unix:///var/run/docker.sock: Post "http://%2Fvar%2Frun%2Fdocker.sock/v1.50/images/create?fromImage=docker.io%2Fwebgoat%2Fgoatandwolf&tag=latest": dial unix /var/run/docker.sock: connect: permission denied
safa@safa-virtual-machine:~/Desktop$ sudo docker pull webgoat/goatandwolf
Using default tag: latest
latest: Pulling from webgoat/goatandwolf
f8416d8bac72: Pull complete
86ae0b0c4c13: Pull complete
7333045f8c26: Downloading 168.6MB/185.2MB
8a5f0348f955: Download complete
a553e7433d6c: Download complete
ddda7d9cdca5: Download complete
4cca113b9964: Download complete
e4e2f5270c00: Download complete
e535ddd94a9f: Download complete
```

```
safa@safa-virtual-machine:~/Desktop$ sudo docker pull webgoat/goatandwolf
Using default tag: latest
latest: Pulling from webgoat/goatandwolf
f8416d8bac72: Pull complete
86ae0b0c4c13: Pull complete
7333045f8c26: Pull complete
8a5f0348f955: Pull complete
a553e7433d6c: Pull complete
ddda7d9cdca5: Pull complete
4cca113b9964: Pull complete
e4e2f5270c00: Pull complete
e535ddd94a9f: Pull complete
48cd64625d9e: Pull complete
ba3693fa8f49: Pull complete
Digest: sha256:7b469c3153aed04298c1f978cfda8a7d5d3789d67577f7d57c7772e58a6de8a3
Status: Downloaded newer image for webgoat/goatandwolf:latest
docker.io/webgoat/goatandwolf:latest
safa@safa-virtual-machine:~/Desktop$
```

```

      .
  /\ /  _ _ _ _ _ ( ) _ _ _ _ _ \ \ \ \ \
( ( ) \ _ _ | ' _ | ' _ | ' _ | ' _ | \ \ \ \ \
  \ / _ _ ) | | ) | | | | | | | | | ( _ | ) ) ) )
    ' | _ _ | . _ | | | | | | | | | _ , | / / / /
=====|_|=====|___/=/_/_/_/_/
:: Spring Boot ::                                (v2.4.3)

```

Activities Firefox 19:37 16 مارس

WebGoat

http://localhost:8081/WebGoat/start.mvc?les...

WEBGOAT

WebGoat

Reset lesson

1

What is WebGoat?

WebGoat is a deliberately insecure application that allows interested developers just like you to *test vulnerabilities* commonly found in Java-based applications that use common and popular open source components.

Now, while we in no way condone causing intentional harm to any animal, goat or otherwise, we think learning everything you can about security vulnerabilities is essential to understanding just what happens when even a small bit of unintended code gets into your applications.

What better way to do that than with your very own scapegoat?

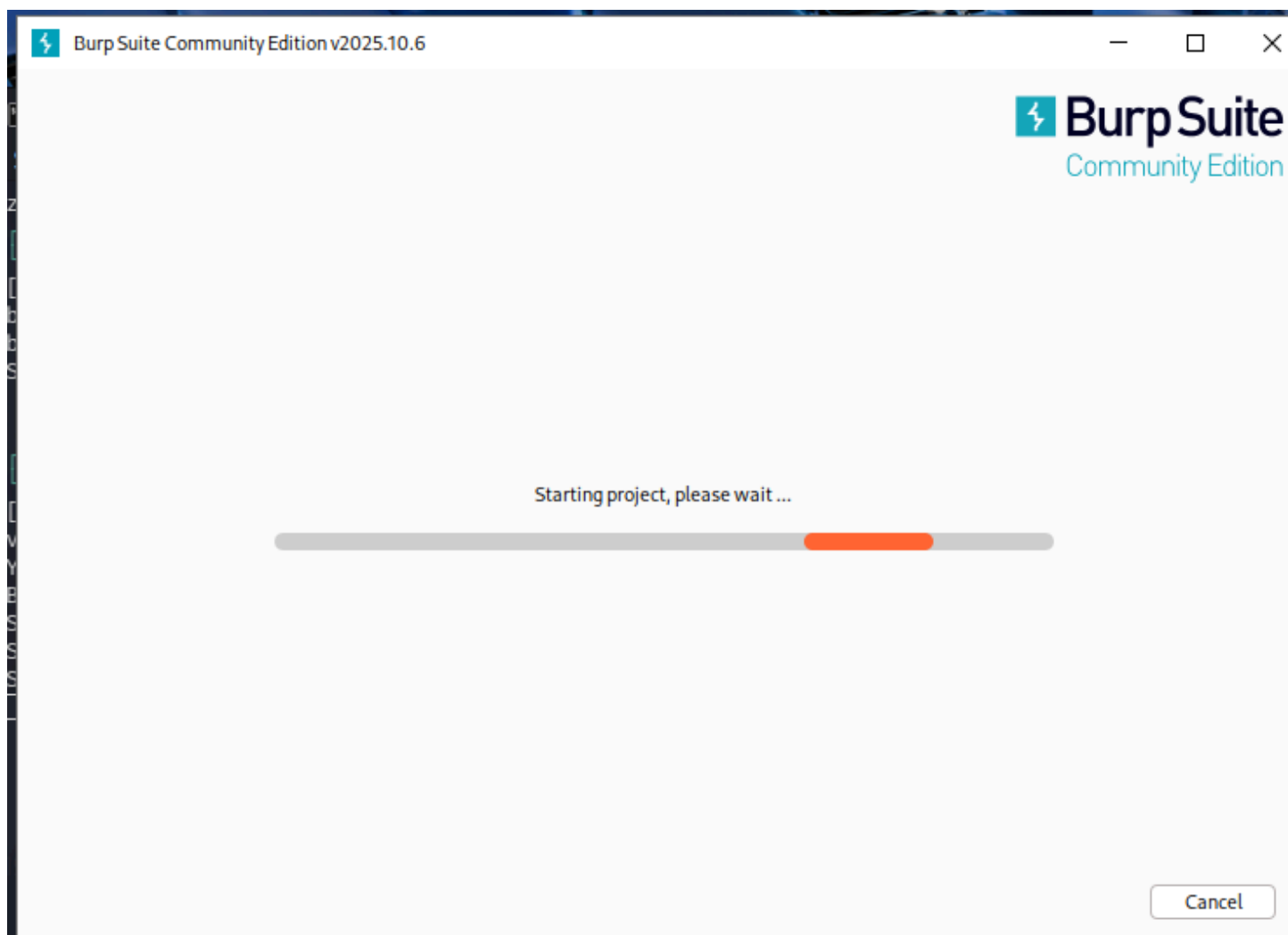
Feel free to do what you will with him. Hack, poke, prod and if it makes you feel better, scare him until your heart's content. Go ahead, and hack the goat. We promise he likes it.

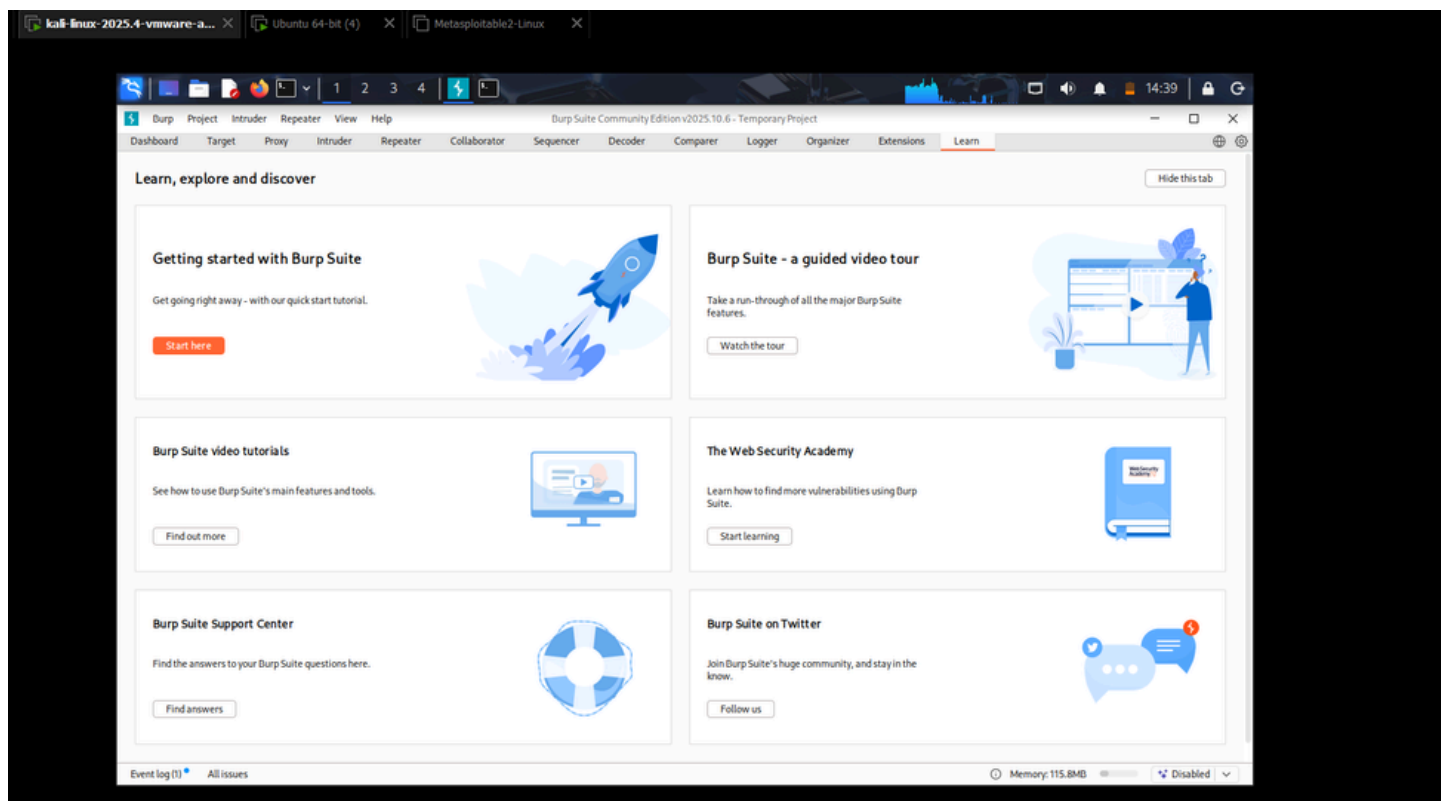
Thanks for your interest!

The WebGoat Team

```
kali@kali: ~/Desktop
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~/Desktop]
$ sudo apt install burpsuite
[sudo] password for kali:
burpsuite is already the newest version (2025.10.6-0kali1).
burpsuite set to manually installed.
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0

(kali@kali)-[~/Desktop]
$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
Your JRE appears to be version 21.0.9 from Debian
Burp has not been fully tested on this platform and you may experience problems.
```





WebGoat x Settings x + -

about:preferences#searchResults

Connection Settings

Configure Proxy Access to the Internet

☐ No proxy

☐ Auto-detect proxy settings for this network

☒ Use system proxy settings

☐ Manual proxy configuration

HTTP Proxy Port

☐ Also use this proxy for HTTPS

HTTPS Proxy Port

SOCKS Host Port

☐ SOCKS v4 ☒ SOCKS v5

☐ Automatic proxy configuration URL

No proxy for

Example: .mozilla.org, net.nz, 192.168.1.0/24
Connections to localhost, 127.0.0.1/8, and ::1 are never proxied.

☐ Do not prompt for authentication if password is saved

Configure Proxy Access to the Internet

- ☐ No proxy
- ☐ Auto-detect proxy settings for this network
- ☐ Use system proxy settings
- ☒ Manual proxy configuration

HTTP Proxy Port

☒ Also use this proxy for HTTPS

HTTPS Proxy Port

SOCKS Host Port

☐ SOCKS v4 ☒ SOCKS v5

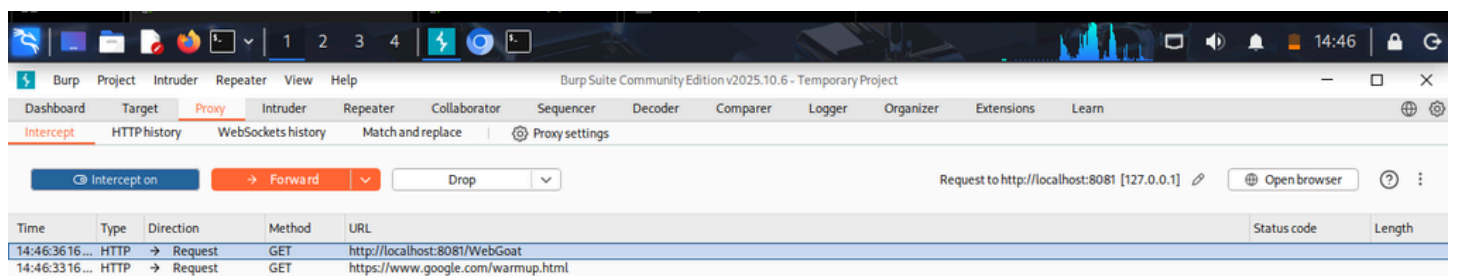
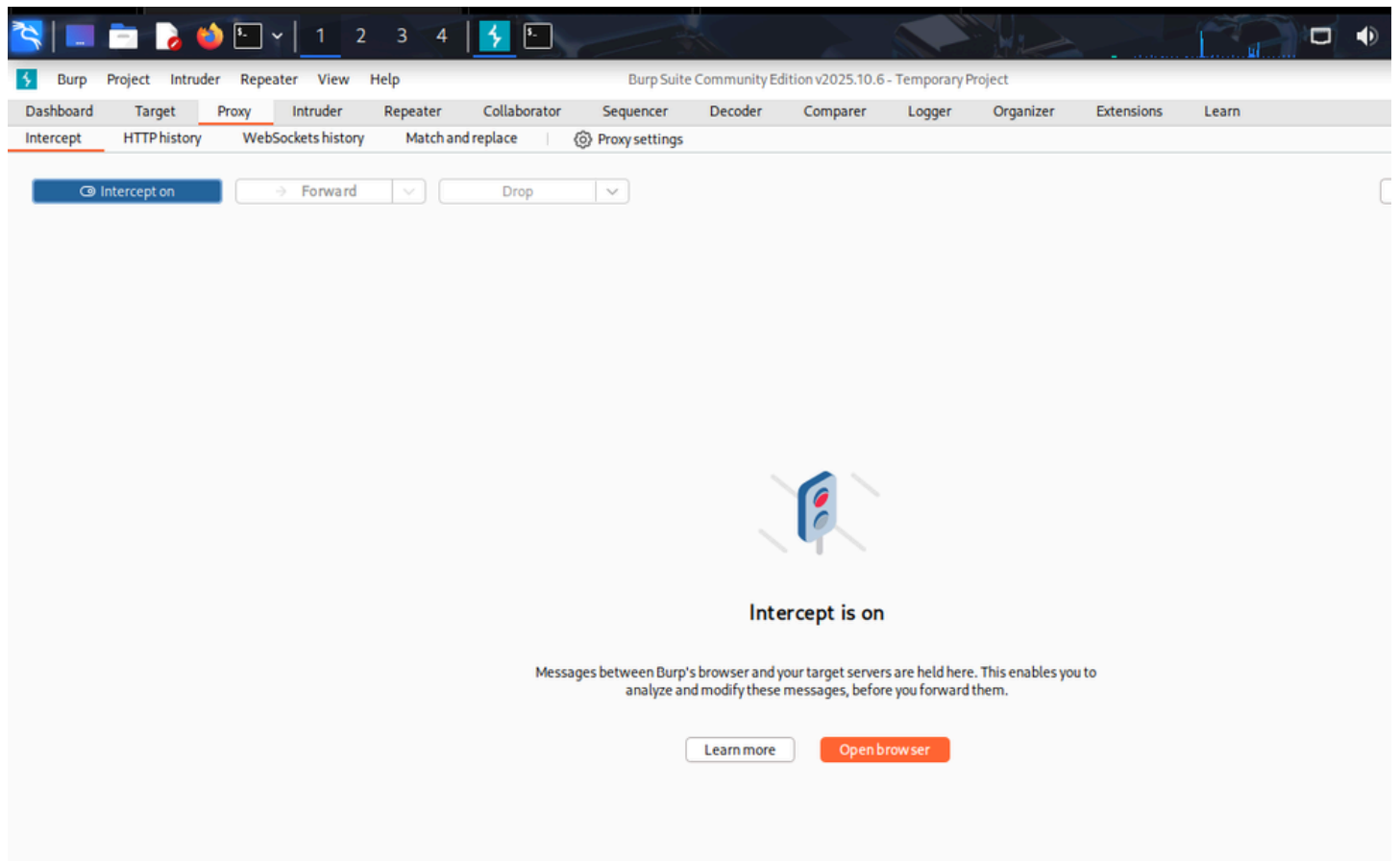
- ☐ Automatic proxy configuration URL

No proxy for

Example: .mozilla.org, .net.nz, 192.168.1.0/24

Connections to localhost, 127.0.0.1/8, and ::1 are never proxied.

☐ Do not prompt for authentication if password is saved



Burp Suite Community Edition v2025.10.6 - Temporary Project										
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Org										
Intercept HTTP history WebSockets history Match and replace Proxy settings										
Filter settings: Hiding CSS and image content; hiding specific extensions										
#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title
1	http://localhost:8081	GET	/WebGoat							
2	https://www.google.com	GET	/warmup.html					HTML	html	
4	https://www.google.com	GET	/warmup.html					HTML	html	
5	http://localhost:8081	GET	/WebGoat							
6	https://www.google.com	GET	/warmup.html					HTML	html	
8	http://localhost:8081	GET	/							
9	https://www.google.com	GET	/warmup.html					HTML	html	

WebGoat

Settings

WebGoat

[http://localhost:8081/WebGoat/start.mvc#lesson/SqlInjection.lesson/3](#)

WEBGOAT

Introduction

General

(A1) Injection

SQL Injection (intro)

SQL Injection (advanced)

SQL Injection (mitigation)

Path traversal

(A2) Broken Authentication

(A3) Sensitive Data Exposure

(A4) XML External Entities (XXE)

(A5) Broken Access Control

(A7) Cross-Site Scripting (XSS)

(A8) Insecure Deserialization

(A9) Vulnerable Components

(A8:2013) Request Forgeries

Client side

Challenges

SQL Injection (intro)

Show hints

Reset lesson

1

2

3

4

5

6

7

8

9

10

11

12

13

Data Definition Language (DDL)

Data definition language includes commands for defining data structures. DDL commands are commonly used to define a database's schema. The schema refers to the overall structure or organization of the database and, in SQL databases, includes objects such as tables, indexes, views, relationships, triggers, and more.

If an attacker successfully "injects" DDL type SQL commands into a database, he can violate the integrity (using ALTER and DROP statements) and availability (using DROP statements) of a system.

- DDL commands are used for creating, modifying, and dropping the structure of database objects.
- CREATE - create database objects such as tables and views
- ALTER - alters the structure of the existing database
- DROP - delete objects from the database
- Example:
 - CREATE TABLE employees(
 - userid varchar(6) not null primary key,
 - first_name varchar(20),
 - last_name varchar(20),
 - department varchar(20),
 - salary varchar(10),
 - auth tan varchar(6)